

# SOC 2 Type II Report

VerifyPro Compliance Solutions S.A.  
Description of the KYC / AML / Sanctions Screening

For the period 2024-11-01 through 2025-10-31

Prepared by:  
**Mazars LLP (Luxembourg)**

Independent Service Auditor's Report

CONFIDENTIAL - FOR INTENDED RECIPIENT USE ONLY

This report is restricted to the management of the service organisation, user entities of the service organisation, and prospective user entities, their auditors, and other parties who have sufficient knowledge to consider it together with other information.

## Section I - Management's Assertion

We have prepared the accompanying description of VerifyPro Compliance Solutions S.A.'s KYC / AML / Sanctions Screening system ("the description") throughout the period 2024-11-01 to 2025-10-31, in accordance with the criteria for a description of a service organisation's system in DC section 200, *Description Criteria for a Description of a Service Organisation's System in a SOC 2 Report* (the description criteria).

We confirm, to the best of our knowledge and belief, that:

- The description fairly presents the system that was designed and implemented throughout the period.
- The controls stated in the description were suitably designed throughout the specified period to provide reasonable assurance that the service organisation's service commitments and system requirements would be achieved based on the applicable trust services criteria.
- The controls operated effectively throughout the period 2024-11-01 to 2025-10-31 to provide reasonable assurance that the service commitments and system requirements were achieved.

Signed:

**Pierre Lemaire, Head of IT Security**

VerifyPro Compliance Solutions S.A.

Dated: 2025-10-31

## Section II - Independent Service Auditor's Report

To the management of VerifyPro Compliance Solutions S.A.:

### Scope

We have examined VerifyPro Compliance Solutions S.A.'s description of its KYC / AML / Sanctions Screening system throughout the period 2024-11-01 to 2025-10-31 (the description) and the suitability of the design and operating effectiveness of controls stated in the description to achieve the related service commitments and system requirements based on the trust services criteria relevant to security, confidentiality, privacy (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*.

### Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of the design and operating effectiveness of controls stated in the description based on our examination. We conducted our examination in accordance with attestation standards established by the AICPA. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is fairly presented and the controls were suitably designed and operating effectively to achieve the service organisation's service commitments and system requirements.

### Inherent Limitations

Because of their nature, controls at a service organisation may not prevent, or detect and correct, all misstatements relating to the achievement of service commitments and system requirements. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions.

### Opinion

**Basis for Qualified Opinion.** As described in Section IV, the controls did not operate effectively throughout the period in respect of: (i) communication of security events to external users (CC2.3); (ii) data retention (P4.2); and (iii) internal monitoring activities (CC4.1). The matters identified in Section IV represent material weaknesses in the operating effectiveness of controls.

In our opinion, except for the matters described in the Basis for Qualified Opinion paragraph and in the 'Description of Tests of Controls and Results' in Section IV, the controls stated in the description were suitably designed and operated effectively throughout the period.

**Mazars LLP (Luxembourg)**

2025-10-31

## Section III - Description of the System

### 3.1 Overview of Operations

VerifyPro provides identity verification, KYC enrichment, sanctions and PEP screening, and adverse media monitoring for Aurora Investment Bank's onboarding and ongoing client due diligence (CDD) workflows. The service ingests customer identity documents (passports, national IDs, proof of address), performs OCR + biometric liveness, screens against global watchlists (OFAC, EU, UN, HMT, MAS, etc.) and returns risk scoring.

Service Organisation Information:

|                  |                                                                                  |
|------------------|----------------------------------------------------------------------------------|
| Legal name       | VerifyPro Compliance Solutions S.A.                                              |
| Headquarters     | Luxembourg                                                                       |
| Incorporation    | RCS Luxembourg B-198724                                                          |
| Founded          | 2012                                                                             |
| Headcount        | ~620 FTEs                                                                        |
| Service category | KYC / AML / Sanctions Screening                                                  |
| Geography        | Primary: Luxembourg + Frankfurt; DR: Dublin. Some processing in Mauritius (Ops). |

### 3.2 Components of the System

#### Infrastructure

The infrastructure supporting the in-scope services consists of physical, virtual and cloud-based components organised across redundant data centres or hyperscale regions, with logical separation by environment (production, pre-production, development) and by tenant.

#### Software

The software stack includes the proprietary application platform, supporting services (databases, message queues, caches, observability), and third-party libraries managed via a controlled software supply chain.

#### People

Operations are delivered by ~620 FTEs across Engineering, Site Reliability, Security, Compliance, Customer Success, and corporate functions. All personnel are subject to background screening and confidentiality obligations.

#### Procedures

Standard operating procedures govern change management, incident management, access management, capacity management, vulnerability management, vendor management and business continuity. Procedures are reviewed at least annually.

#### Data

Data processed by the system includes: Full client PII: name, DOB, nationality, address, government ID numbers; Identity documents: passport scans, national ID images, utility bills; Biometric data: facial images and liveness video frames; Beneficial ownership and corporate structure data; Transaction screening payloads for AML monitoring

### 3.3 Subservice Organisations

VerifyPro Compliance Solutions S.A. relies on the following subservice organisations. The description is presented using the carve-out method; the controls of subservice organisations are not included in the scope of this report. Complementary subservice organisation controls (CSOC) expected to be in place at each subservice organisation are identified below.

| Subservice Organisation               | Service Provided                                 | Location       |
|---------------------------------------|--------------------------------------------------|----------------|
| Microsoft Ireland Operations Ltd.     | Azure cloud hosting (EEA)                        | Ireland        |
| Onfido Ltd.                           | Document & biometric verification (sub-supplier) | United Kingdom |
| LexisNexis Risk Solutions             | Watchlist data feed                              | United States  |
| VerifyPro Operations (Mauritius) Ltd. | Manual review of KYC exceptions                  | Mauritius      |
| Twilio Ireland Ltd.                   | SMS OTP                                          | Ireland        |

### 3.4 Significant Changes During the Period

Onboarded internal Mauritius operations centre for KYC exception review in Mar 2025. Internal Audit function vacant from Nov 2024 to Mar 2025.

## Section IV - Description of Controls and Tests of Controls

The following control activities, as designed and implemented by the service organisation, were tested by the service auditor during the period. The table summarises a representative subset; the complete control matrix is available upon request under NDA.

| Ref   | Domain                                         | Control                                                                                                | Test Procedure                                                | Result               |
|-------|------------------------------------------------|--------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|----------------------|
| CC1.1 | COSO - Control Environment                     | The Board of Directors and senior management demonstrate a commitment to integrity and ethical values. | Inspected Board minutes and senior management communications. | No exceptions noted. |
| CC2.1 | COSO - Communication of Internal Control       | Internal information requirements are communicated to all personnel.                                   | Inspected internal policy and procedure approvals.            | No exceptions noted. |
| CC3.1 | COSO - Risk Assessment                         | An enterprise risk register is maintained and reviewed at least annually.                              | Inspected and reviewed enterprise risk register.              | No exceptions noted. |
| CC6.1 | Logical Access - Identity                      | Users are uniquely identified prior to access being granted.                                           | Inspected user provisioning configuration.                    | No exceptions noted. |
| CC6.2 | Logical Access - Authentication                | Access is approved by data owner.                                                                      | Inspected basis of evidence.                                  | No exceptions noted. |
| CC6.3 | Logical Access - User Privileges               | Privileges are reviewed at least quarterly.                                                            | Inspected quarterly access review.                            | No exceptions noted. |
| CC6.6 | Logical Access - External Access               | External access is permitted only via approved configuration.                                          | Inspected configuration of VPN.                               | No exceptions noted. |
| CC6.7 | Logical Access - Restriction of Access to Data | Access to data is restricted based on definitions.                                                     | Reviewed access events.                                       | No exceptions noted. |
| CC7.1 | System Operations - Vulnerability Management   | Vulnerability is managed, assessed and vulnerability scans are performed.                              | Reviewed vulnerability scans.                                 | No exceptions noted. |
| CC7.4 | System Operations - Incident Management        | Security events are detected, triaged and resolved.                                                    | Inspected incident response.                                  | No exceptions noted. |
| A1.2  | Availability - Capacity                        | Capacity is monitored against thresholds.                                                              | Inspected capacity dashboards.                                | No exceptions noted. |
| C1.1  | Confidentiality - Data Classification          | Classification information is identified and protected.                                                | Inspected data classification policy.                         | No exceptions noted. |
| CC4.1 | Internal Monitoring                            | Internal audit conducts ongoing monitoring activities.                                                 | Inspected internal audit work plan.                           | Exceptions noted.    |
| P4.2  | Privacy - Retention                            | Personal data is retained only as long as necessary and for legal compliance.                          | Inspected retention and deletion policies.                    | No exceptions noted. |

### 4.1 Description of Exceptions Noted

#### 4.1.A - CC2.3 - Communication of Security Events to External Users

**Description:** For 2 of 11 sampled security incidents during the period, customer notifications were issued more than 72 hours after detection (88 hours and 143 hours respectively), exceeding the policy commitment of 'without undue delay, not later than 72 hours'.

**Management response:** VerifyPro is implementing automated incident notification workflow expected Q4 2025.

#### 4.1.B - P4.2 - Data Retention

**Description:** Customer-controlled retention period is documented as 'configurable, default 10 years post-offboarding'. For 7 of 25 sampled deactivated tenants, identity documents were retained beyond the contractually requested deletion date (median 41 days, max 113 days).

**Management response:** A new automated tenant-deletion job is being deployed in Q1 2026.

#### 4.1.C - CC4.1 - Internal Audit / Continuous Monitoring

**Description:** The internal audit function was vacant for ~5 months during the period and no control monitoring activities were performed during that interval.

**Management response:** An interim Head of Internal Audit was hired in March 2025; a permanent appointment was confirmed in July 2025.

## Section V - Other Information Provided by Management

The following information is provided by management for the convenience of report users and has not been subjected to procedures applied in the examination.

### Roadmap and Continuous Improvement

Q2 2026: Automated incident notification and tenant deletion. Q3 2026: ISO 27001:2022 transition certification. Q4 2026: Reduction of default retention to 7 years.

### Customer Complementary User Entity Controls (CUECs)

- User entities are responsible for managing logical access for their own users to the service.
- User entities are responsible for ensuring data uploaded to the service is appropriate for processing under the agreement.
- User entities are responsible for monitoring service usage for anomalies.
- User entities are responsible for keeping API tokens and SSO certificates current.

*End of report.*